

Chapter 4 – Security Assertion Markup Language (SAML 2.0)

Learning Objectives

After completing this chapter, you should be able to:

- Understand why SAML exists.
 - Explain the SAML authentication flow.
 - Identify the roles of the Identity Provider (IdP) and Service Provider (SP).
 - Explain Assertions, NameID, ACS URL, Entity ID, Metadata, and Certificates.
 - Understand SP-Initiated and IdP-Initiated SSO.
 - Configure SAML conceptually for Google Workspace.
 - Troubleshoot common SAML failures.
-

1. Business Problem

Imagine a company with the following applications:

- Google Workspace
- Salesforce
- Workday
- ServiceNow
- Slack
- Zoom

Without Single Sign-On (SSO), employees would need separate usernames and passwords for each application.

Problems:

- Password fatigue
- Password reuse
- Increased help desk tickets
- Inconsistent security policies
- Difficult user lifecycle management

The organization wants employees to authenticate once and access multiple applications securely.

This is where **SAML** comes in.

2. What is SAML?

Security Assertion Markup Language (SAML) is an XML-based standard used to exchange authentication and authorization information between an Identity Provider (IdP) and a Service Provider (SP).

Simply put:

SAML allows one trusted system to authenticate users for another system.

Example:

Instead of Google verifying your password,

Google asks:

"Has Okta already authenticated this user?"

If Google trusts Okta's response,

the user is allowed to access Gmail.

3. Key Components

Component	Purpose
User	Person accessing the application
Browser	Carries SAML messages between IdP and SP
Identity Provider (IdP)	Authenticates the user
Service Provider (SP)	Provides the application
Assertion	Authentication information
Certificate	Verifies the assertion signature

Enterprise Example

Company

Contoso Ltd.

Identity Provider

Microsoft Entra ID

Applications

- Google Workspace
- Salesforce
- ServiceNow

Employees authenticate with Microsoft Entra ID.

Google Workspace trusts Microsoft Entra ID.

Employees enter their password only once.

4. SAML Authentication Flow

The following example shows an SP-Initiated login.

User

↓

Open Gmail

↓

Google Workspace (SP)

↓

Redirect user to Identity Provider

↓

User enters credentials

↓

Identity Provider verifies credentials

↓

Identity Provider creates SAML Assertion

↓

Assertion is digitally signed

↓

Browser sends Assertion to Google

↓

Google verifies signature

↓

Assertion valid?

↓

Yes

↓

User logged into Gmail

Notice:

Google never sees the user's password.

Only the Identity Provider does.

5. Identity Provider (IdP)

The Identity Provider performs authentication.

Examples:

- Google Identity
- Microsoft Entra ID
- Okta
- Ping Identity

Responsibilities:

- Verify credentials
 - Enforce MFA
 - Generate SAML Assertions
 - Digitally sign assertions
-

6. Service Provider (SP)

The Service Provider hosts the application.

Examples:

- Gmail
- Salesforce
- ServiceNow
- Slack
- Zoom

Responsibilities:

- Redirect users to the IdP
- Validate SAML Assertions
- Create application sessions

The SP trusts the IdP instead of storing passwords.

7. SAML Assertion

The Assertion is the most important part of SAML.

Think of it as an identity document.

It contains information such as:

- User identity
- Authentication status
- Login time
- Expiration time
- Attributes
- Digital signature

Google relies on this Assertion to determine whether authentication was successful.

Example Assertion Contents

```
Subject
rahul@company.com

Authentication Time

09:15 UTC

Issuer

Okta

Audience

Google Workspace

Expiration

09:20 UTC

Attributes

Email
Department
Employee ID

Digital Signature
```

The actual Assertion is XML, but conceptually it carries the information above.

8. NameID

The NameID uniquely identifies the user.

Examples:

```
rahul@company.com
```

or

12345678

Google expects the NameID to match the configured user identity.

If the NameID is incorrect,

Google cannot determine which account is signing in.

Example

Google user:

rahul@company.com

SAML Assertion:

rahul@company.com

Authentication succeeds.

If the Assertion contains:

rahul.personal@gmail.com

Google cannot match it to the Workspace account.

Authentication fails.

9. ACS URL

ACS stands for **Assertion Consumer Service**.

It is the endpoint where the Service Provider receives the SAML Assertion.

Flow:

Identity Provider

↓

Sends Assertion

↓

ACS URL

↓

Google validates it

If the Assertion is sent to the wrong ACS URL,
authentication fails.

10. Entity ID

Every IdP and SP has a unique identifier called the Entity ID.

Think of it as an identity for systems.

Example:

Identity Provider

`https://idp.company.com`

Service Provider

`google.com`

The Entity ID ensures that assertions are exchanged between trusted systems.

11. Metadata

Metadata contains configuration information used to establish trust.

Typical metadata includes:

- Entity ID
- ACS URL
- Certificates
- Endpoints
- Supported bindings

Instead of configuring every value manually,

organizations often exchange metadata files.

12. Certificates

The Identity Provider signs every Assertion using its private key.

Google verifies the signature using the IdP's public certificate.

This ensures:

- Authenticity
 - Integrity
 - Trust
-

Digital Signature Flow

Identity Provider

↓

Create Assertion

↓

Sign with Private Key

↓

Browser

↓

Google Workspace

↓

Verify with Public Certificate

↓

Signature Valid?

↓

Yes

↓

Accept Assertion

Why is the Signature Important?

Suppose an attacker changes the Assertion.

Original:

Role = User

Modified:

Role = Super Admin

The signature no longer matches.

Google rejects the Assertion.

This prevents tampering.

13. SP-Initiated Login

The user starts at the application.

Example:

Open

mail.google.com

Google redirects the user to the Identity Provider.

After successful authentication,

the user returns to Gmail.

This is the most common SSO flow.

14. IdP-Initiated Login

The user starts at the Identity Provider.

Example:

Open

https://login.company.com

The user authenticates.

The IdP displays available applications.

The user selects Gmail.

The IdP sends the Assertion directly to Google.

SP-Initiated vs IdP-Initiated

SP-Initiated	IdP-Initiated
User starts at the application	User starts at the IdP
SP redirects to IdP	IdP launches the application

SP-Initiated	IdP-Initiated
Most common	Common in application portals
Better user experience for direct app access	Central application dashboard

15. Common SAML Failures

Invalid Certificate

Cause:

The IdP rotated its signing certificate.

Google still trusts the old certificate.

Solution:

Update the certificate in Google Workspace.

NameID Mismatch

Cause:

The Assertion contains the wrong identifier.

Solution:

Ensure the NameID matches the Google Workspace user.

Incorrect ACS URL

Cause:

The Assertion is sent to the wrong endpoint.

Solution:

Verify the ACS URL configuration.

Assertion Expired

Cause:

The Assertion exceeded its validity period.

Possible reasons:

- Clock skew
- Delayed request
- Incorrect system time

Invalid Signature

Cause:

The Assertion was modified or signed with an unexpected key.

Google rejects the request.

16. SAML Troubleshooting

When SSO fails,

avoid random configuration changes.

Ask:

1. Did the user authenticate at the IdP?
2. Was the Assertion generated?
3. Is the NameID correct?
4. Is the certificate valid?
5. Does the signature verify?
6. Is the ACS URL correct?
7. Has the Assertion expired?

This systematic approach helps identify the root cause quickly.

Real Enterprise Scenario

A company uses Okta as its Identity Provider.

Users suddenly cannot access Gmail.

Investigation reveals:

- Passwords are correct.
- MFA succeeds.
- Okta generated the Assertion.
- The signing certificate expired yesterday.

Resolution:

Update the trusted certificate in Google Workspace.

SSO works again.

Best Practices

- Use trusted certificates.
 - Monitor certificate expiration dates.
 - Test SSO after configuration changes.
 - Keep IdP metadata up to date.
 - Validate NameID mappings.
 - Enable MFA at the Identity Provider.
-

Common Mistakes

- ✗ Using the wrong ACS URL.
- ✗ Incorrect NameID mapping.
- ✗ Forgetting to update certificates.
- ✗ Ignoring clock synchronization.

✗ Modifying production SAML settings without testing.

Interview Questions

1. What problem does SAML solve?
 2. What is the difference between an Identity Provider and a Service Provider?
 3. What is a SAML Assertion?
 4. What is the purpose of the NameID?
 5. What is the ACS URL?
 6. Why are certificates required in SAML?
 7. Explain SP-Initiated and IdP-Initiated SSO.
 8. How would you troubleshoot a SAML login failure?
-

Chapter Summary

In this chapter you learned:

- ✓ Why SAML exists.
- ✓ The roles of the IdP and SP.
- ✓ The complete SAML authentication flow.
- ✓ Assertions.
- ✓ NameID.
- ✓ ACS URL.
- ✓ Entity ID.
- ✓ Metadata.
- ✓ Certificates and digital signatures.

✓ SP-Initiated and IdP-Initiated SSO.

✓ Common SAML failures and troubleshooting.

The next chapter covers **OAuth 2.0**, where you'll learn how applications obtain authorization to access Google Workspace resources without using user passwords, including access tokens, refresh tokens, scopes, and consent.